SOC L1 LAB · INC-005

INC-005 — Detailed Findings Report

An outbound SYN sweep, and the legitimate burst that looks the same

INCIDENT	INC-005 — Outbound port scan
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	Medium

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Executive summary
2. Scope and methodology
3. Environment
4. False-positive baseline
5. Attack narrative
6. Timeline
7. Evidence
8. Detection analysis
9. Assessment and root cause
10. Impact
11. Severity
12. Response actions
13. Recommendations
14. Lessons learned

Appendix A — Suricata rule
Appendix B — MITRE ATT&CK
Appendix C — Evidence index
Appendix D — Glossary

Incident	INC-005 — Outbound port scan
Classification	Lab exercise, sanitized for publication
Activity date	2026-10-31
Report date	2026-11-01
Author	SOC L1 portfolio lab
Status	Closed — escalated for verification
Severity	Medium (reconnaissance)
Related	`tickets/INC-005-port-scan.md` , `rules/inc-005-rules.md` , `docs/evidence/INC-005-*`

---

1. Executive summary

At 23:26:35 UTC, the endpoint scanned 200 TCP ports on its gateway (`10.0.2.2`) in under a second. Suricata produced **144 alerts** for signature `LAB SCAN outbound SYN sweep` ; Wazuh ingested them as rule 86601.

This is a reconnaissance alert, not an exploitation alert. The host did not authenticate, write files, or establish a session. The finding is that an internal host performed a sweep, which in a real estate raises one question: **is this an approved scanner, or a compromised host doing discovery?**

The custom rule was tested first against legitimate traffic:

Legitimate activity	Alerts
Normal `apt` + `curl` traffic	0
40 requests in one burst	0
60 requests in one burst	**10** (false positive)

The 50-SYN/5-second threshold is the boundary. A load test or a busy health checker can cross it. That is documented rather than hidden.

The scenario is **outbound-only** because the VM uses QEMU user networking. The host cannot scan the guest's full port range without the optional tap/bridge upgrade. The ticket and detection guide say so plainly; the alternative would be to claim an inbound scan the lab cannot produce.

---

2. Scope and methodology

2.1 Scope

In scope	Out of scope
One Debian 12 VM (`soc-victim` , 10.0.2.15)	Production systems
Suricata 7.0.10 on `ens3`	Internet-facing targets
Custom Suricata rule 1000001	Real exploitation
Local nmap scan of the QEMU gateway	Employer or client data

2.2 Method

1. Confirm Suricata and the Wazuh forwarding pipeline.
2. Add a local Suricata rule for an outbound SYN sweep.
3. Measure false positives with normal traffic, a 40-request burst, and a 60-request burst.
4. Run `nmap -sS --top-ports 200` from the victim to the gateway.
5. Verify Suricata and Wazuh alerts, export evidence, and write the ticket.

2.3 Limitations

- **Direction.** QEMU user networking forwards individual ports; the host cannot reach the guest's full port range. The scan is outbound from the victim.
- **Target.** One destination (`10.0.2.2`), not a subnet. A subnet sweep would look more like a real discovery scan.
- **One sensor.** Suricata sits on the victim's `eth0` ; no network tap.
- **No exploitation.** The scan is the whole event.

---

3. Environment

Component	Detail
SIEM	Wazuh 4.14.7
Endpoint	Debian 12, 1.5 GB VM
Sensor	Suricata 7.0.10, `ens3` , 8,234 ET Open rules + local rule
`HOME_NET`	`10.0.2.15/32`
`EXTERNAL_NET`	`!$HOME_NET`
Filter	`eve.json` → `wazuh.json` (alerts/http/dns)
Attacker	`nmap` inside the VM
Rules	Wazuh 86601 (Suricata alert), custom Suricata sid 1000001

The local Suricata rule:

```
alert tcp $HOME_NET any -> $EXTERNAL_NET any (
  msg:"LAB SCAN outbound SYN sweep";
  flags:S;
  detection_filter: track by_src, count 50, seconds 5;
  classtype:attempted-recon;
  sid:1000001; rev:1;
)
```

It counts SYN packets from the victim, not unique destinations. That is the source of the false-positive boundary in §4.

---

4. False-positive baseline

Phase	Traffic	Alerts
Normal	`apt-get update`, `curl https://deb.debian.org/`, one `curl` to the lab	0
Burst 1	40 HTTP requests in a tight loop	0
Burst 2	60 HTTP requests in a tight loop	**10** at 23:26:28

The 60-request burst produced ten `LAB SCAN` alerts with `dest_port=8080`. That is a legitimate load test crossing the threshold, not an attack.

Operational consequence: the rule needs a baseline of known scanners and monitoring bursts. Raising the threshold alone is not enough; a real scan can be slow and a real load test can be fast. Correlation with follow-on behaviour is the discriminator.

---

5. Attack narrative

```
sudo nmap -sS --top-ports 200 --min-rate 500 10.0.2.2
```

The scan completed in 0.20 s. Suricata recorded SYNs to ports including 1074, 808, 2121, and many others. The alert cluster:

Time (UTC)	Events
23:26:35	5
23:26:36	139
Total	**144**

Wazuh rule 86601:

```
Suricata: Alert - LAB SCAN outbound SYN sweep
```

No authentication, file write, process execution, or outbound connection followed the scan. The source is the victim itself (`10.0.2.15`), which models a compromised host performing discovery.

---

6. Timeline

Time (UTC)	Event
23:26:26	Normal traffic; no alerts
23:26:28	60-request legitimate burst; 10 alerts (FP)
23:26:35	nmap scan starts
23:26:35–36	144 scan alerts
23:26:40	Scan completes; no further activity
23:27	Evidence exported

---

7. Evidence

7.1 Alert counts

Source	Count
Suricata `LAB SCAN` events	305 (includes a repeat scan)
Wazuh 86601 in the window	335 (includes follow-on scan)
FP burst	10
Attack scan	144 (first run)

7.2 Sample Suricata event


```
{
  "timestamp": "2026-10-31T23:26:35.482178+0000",
  "event_type": "alert",
  "src_ip": "10.0.2.15",
  "dest_ip": "10.0.2.2",
  "dest_port": 1074,
  "alert": {
    "signature_id": 1000001,
    "signature": "LAB SCAN outbound SYN sweep",
    "category": "Attempted Information Leak"
```

```
  }
}
```

7.3 Scan output

`docs/evidence/INC-005-scan.txt` contains the nmap result. The gateway exposed port `8080`; the rest were closed or filtered.

---

8. Detection analysis

8.1 What fired

Layer	Signal	Value
Network	Suricata sid 1000001	SYN sweep
SIEM	Wazuh 86601	Alert ingestion
Host	none	No process or file change

8.2 Why a custom rule

ET Open's scan rules are largely direction-sensitive (`$EXTERNAL_NET -> $HOME_NET`). The lab's scan is outbound (`$HOME_NET -> $EXTERNAL_NET`), so many stock signatures do not match. A local rule makes the outbound case explicit and testable.

8.3 False-positive boundary

The rule counts packets, not destinations. A busy client, a load test, or a monitoring burst can cross 50 SYNs in 5 seconds. Options:

- raise the threshold and accept slower detection;
- track unique destinations (needs a different tool/rule model);
- baseline known scanners and load generators;
- correlate with authentication failures, process activity, or egress.

8.4 Gaps

Gap	Consequence
Outbound-only	An inbound scan of the VM is not covered
One destination	A real subnet sweep would look different
Packet-count threshold	60 legitimate requests trigger it
Slow scan below threshold	Evades the rule
No follow-on correlation	A scan + exploit is two separate alerts

---

9. Assessment and root cause

This is **reconnaissance**, not compromise. The root cause is an internal host making a SYN sweep; the detection question is why.

Three explanations, in order of likelihood for a real estate:

1. An approved vulnerability scanner or asset inventory tool.
2. A compromised host performing discovery.
3. A misconfigured monitoring or load-testing job.

No evidence supports 2 in this lab. The ticket asks for the scanner schedule and the host owner.

---

10. Impact

Dimension	Assessment
Confidentiality	Low alone; the scan reveals open ports
Integrity	None
Availability	None
Blast radius	One source, one destination
Escalation potential	High if followed by authentication or exploitation

A scan is a precursor. The severity comes from what happens next, not from the SYNs.

---

11. Severity

Medium.

- **Not High:** no exploitation, no successful session, one host, one destination.
- **Not Low:** an internal host scanning its gateway is unusual and warrants verification; if the host is compromised, the next step is lateral movement.

Raise to High if the same source produces authentication failures or exploit attempts within the following hour. Raise to Critical if a session or payload follows.

---

12. Response actions

1. Confirmed the scan source was the lab VM and the destination was the gateway.
2. Checked for follow-on authentication, file changes, or new outbound connections.
3. Found none.
4. Preserved the Suricata events, Wazuh alerts, and nmap output.

5. Escalated for scanner-schedule verification.

---

13. Recommendations

Detection

#	Action
1	Raise the threshold or baseline known scanners/load tests
2	Add unique-destination tracking or use a flow-based scan detector
3	Correlate scan → auth failures → exploit attempts
4	Add the inbound case if the bridge upgrade is deployed
5	Keep the rule at a level that triggers triage, not paging

Operational

#	Action
6	Maintain a scanner inventory with source addresses
7	Schedule scans and feed them to the SOC
8	Segment the lab/management network from user traffic
9	Restrict egress from the web tier
10	Document the QEMU direction limitation in the lab guide

---

14. Lessons learned

- **Direction matters.** A rule written for inbound scans misses outbound discovery.
- **A threshold is a trade-off.** 50/5s detects fast scans and fires on a 60-request load test.
- **A scan is not a breach.** The ticket should say what did *not* happen.
- **The lab limitation is part of the finding.** Claiming an inbound scan without the bridge would be dishonest.

Appendix A — Suricata rule

```
alert tcp $HOME_NET any -> $EXTERNAL_NET any (
  msg:"LAB SCAN outbound SYN sweep";
  flags:S;
  detection_filter: track by_src, count 50, seconds 5;
  classtype:attempted-recon;
```

```
  sid:1000001; rev:1;
)
```

Appendix B — MITRE ATT&CK

Technique	ID	Evidence
Network service discovery	T1046	SYN sweep across 200 ports
Active scanning	T1595	nmap from the victim

Appendix C — Evidence index

File	Contents
`docs/evidence/INC-005-alerts.json`	Wazuh alerts in the window
`docs/evidence/INC-005-suricata.json`	Suricata `LAB SCAN` events
`docs/evidence/INC-005-scan.txt`	nmap output
`docs/evidence/INC-005-fp.txt`	False-positive baseline
`docs/evidence/INC-005-rule.txt`	The local rule

Appendix D — Glossary

Term	Meaning
SYN sweep	Sending TCP SYN packets to many ports
`detection_filter`	Suricata threshold/aggregation directive
`HOME_NET`	Suricata's protected network
`EXTERNAL_NET`	Everything outside `HOME_NET`